

BUSINESS CASE: ISO/IEC 27001:2022 CERTIFICATION

Tumaini Capital Ltd | Prepared by: Head of Risk & Compliance | June 2026 | For: CEO & Executive Committee

Company: Tumaini Capital Ltd

Tumaini Capital is a digital lending and microfinance company headquartered in Nairobi's Upper Hill, with a satellite office in Kisumu. Founded in 2019, the company has grown to 85 employees and serves roughly 120,000 active borrowers across Kenya through a mobile app and a USSD channel. Its core product is short-term digital loans disbursed and repaid via M-Pesa, alongside a newer SME lending product that requires more extensive KYC documentation, including national ID copies, payslips, and bank statements.

The company's technology stack includes a core lending platform hosted on AWS (Nairobi customers served from the eu-west-1 region), a customer relationship management system, an internal HR and payroll system, and integrations with Safaricom's M-Pesa API and two credit reference bureaus. Staff use a mix of company-issued laptops and BYOD phones, and most departments rely heavily on email, WhatsApp Business, and shared Google Workspace drives for day-to-day collaboration.

1. PURPOSE — WHY NOW

Three pressures have converged: a regional bank white-label partnership is stalled pending evidence of a certified ISMS; the Office of the Data Protection Commissioner (ODPC) is increasing enforcement under the Data Protection Act, 2019, against a backdrop of significant KYC and financial data processing; and an unresolved offboarding control gap recently allowed an ex-employee's CRM access to remain active, resulting in unauthorized data export.

2. KEY BENEFITS

- Unlocks the regional bank partnership — a revenue-generating opportunity currently blocked by procurement and risk due diligence requirements.
- Strengthens regulatory standing ahead of anticipated ODPC audits of digital lenders.
- Formalizes access control and offboarding processes, directly closing the gap exposed by the CRM incident.
- Provides credible, auditable evidence for future enterprise partners, investors, and regulators.

3. FINANCIAL CONSIDERATIONS

Cost category	Estimated range (KES)
Certification body audit fees (Stage 1 & 2)	600,000 – 1,200,000
External lead implementer / consultant support	800,000 – 1,800,000
Tooling (GRC platform, vuln. scanning, log mgmt.)	300,000 – 700,000
Internal staff time (ISMS Lead, Engineering, Ops)	Largest cost — reallocated time, not new headcount
Remediation of gaps (gap analysis dependent)	To be confirmed after gap analysis

Indicative total direct cost (excl. internal staff time): approx. KES 1.7M – 3.7M. Figures will be refined once the gap analysis is complete.

4. RISK

- Risk of inaction: continued loss of the bank partnership revenue, exposure to ODPC enforcement/fines, recurrence of unauthorized access incidents, and reputational damage.
- Risk of under-resourcing: the 12-month timeline assumes the ISMS Lead and relevant Engineering staff are freed from competing priorities; without this, both timeline and audit readiness will slip.

5. ESTIMATED TIMELINE (≈10–12 MONTHS)

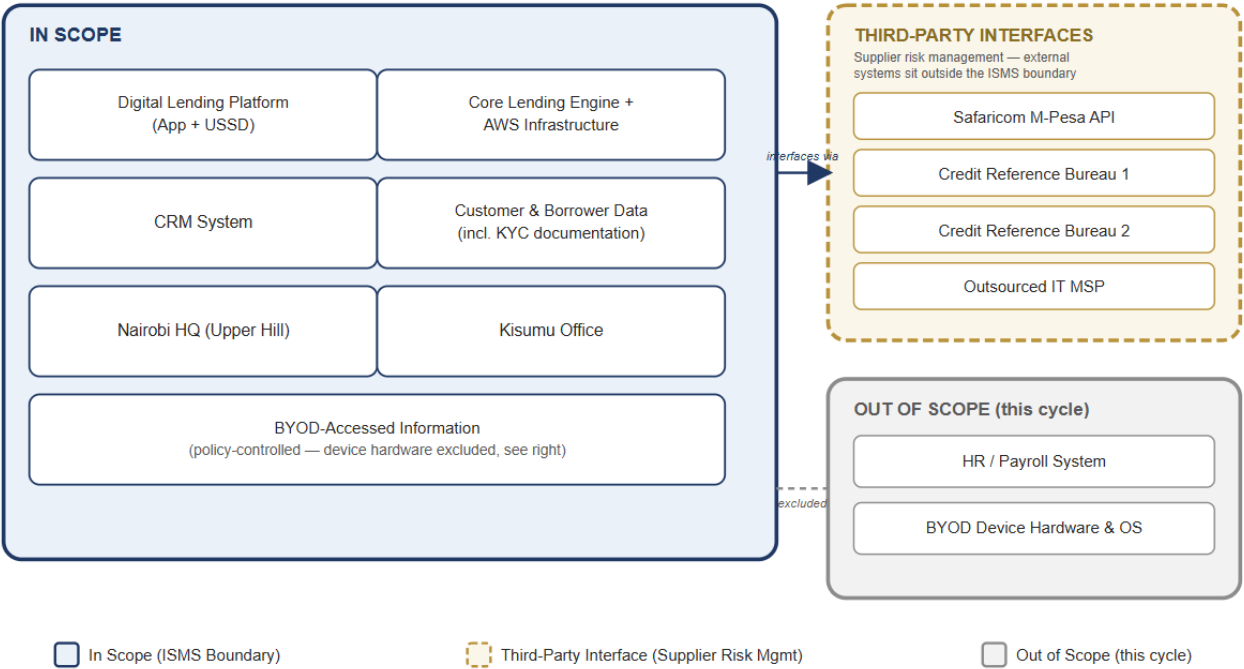
Phase	Duration
Gap analysis & scope definition	4–6 weeks
Risk assessment & treatment planning	4–6 weeks
Control implementation & policy rollout	4–5 months
Internal audit & management review	4–6 weeks
Stage 1 & Stage 2 certification audits	4–8 weeks

6. RECOMMENDATION

- Approve pursuit of ISO/IEC 27001:2022 certification with a 12-month target.
- Formally appoint the Head of Risk & Compliance as ISMS Lead, with cross-departmental authority.
- Approve indicative budget above and confirm allocation of staff time for the project duration.
- Authorize the next step: a formal gap analysis to confirm scope and refine cost/timeline estimates.

Tumaini Capital Ltd — ISMS Scope Boundary

ISO/IEC 27001:2022 — Clause 4.3 (fictional case study)



Note: information accessed via BYOD devices is in scope; the underlying device hardware/OS is not owned by Tumaini Capital and is therefore excluded.